CURSO PARA INTEGRADORES DO HUBSAÚDE · MÓDULO EXTRA, OPCIONAL

+ Assinar com o Safira

Este módulo é opcional. A assinatura digital só é necessária quando o Guia de Implementação do serviço a exige para o tipo de registro que o seu sistema envia. Neste módulo, você vê o que a assinatura comprova e pratica a assinatura e a conferência com o Safira, no modo simulação, sem precisar de um certificado ICP-Brasil.

AO FINAL, VOCÊ SERÁ CAPAZ DE

- ✓ explicar o que a assinatura digital comprova e como ela difere da autenticação;
- ✓ identificar o papel do Bundle, do Provenance e da Signature;
- ✓ assinar e validar um registro no modo simulação, sem certificado ICP-Brasil;
- ✓ interpretar a recusa de uma assinatura.

COMO O MÓDULO ESTÁ ORGANIZADO

1. **Conceitos:** seções E.1 a E.4
2. **Prática guiada:** 5 passos no terminal
3. **Verificação:** perguntas, glossário e respostas

VOCÊ VAI PRECISAR

- O Java 21 instalado e o programa do Safira, o arquivo `hubsaude-safira-X.Y.Z.jar`, renomeado como `hubsaude-safira.jar` e salvo na pasta `curso-hubsaude`.
- O programa `jq`, instalado no módulo 2.
- Os arquivos `bundle-assinatura.json` e `provenance.json`: o conteúdo está neste material, e os dois podem ser baixados na página Materiais do curso.

ASSISTA AOS VÍDEOS

Aponte a câmera do celular para o código.

SEÇÕES E.1 A E.4 E PASSOS 2 A 5

Como a assinatura protege um registro

5 min 5 s, com narração e legendas

DÚVIDAS E SUGESTÕES

Se algum passo ficar difícil, escreva para o suporte do HubSaúde, em `suporte@saude.go.gov.br`, com o assunto "Curso para integradores, módulo extra". A versão mais recente deste módulo, com os vídeos, está em `https://sesgo-ti.github.io/hubsaude/curso/safira/`.

Copiar de um PDF pode alterar aspas, hífens e quebras de linha. Para os comandos e arquivos, prefira a versão do módulo no portal ou os arquivos para baixar, em `https://sesgo-ti.github.io/hubsaude/curso/materiais/`.

PARTE 1

Conceitos

E.1 Autenticação e assinatura: papéis diferentes

No módulo 4, o seu sistema já usou um certificado: assinou o `client_assertion` e se apresentou na conexão mTLS. Isso prova quem é o sistema conectado, mas essa prova vale apenas para a conexão e para um token de poucos minutos. Depois que o registro chega, nada nele mostra quem respondeu pelo conteúdo.

A **assinatura digital** acrescenta essa garantia ao próprio registro. Ela fica gravada junto com ele e comprova duas coisas: **quem** respondeu pelo conteúdo e que **nada mudou** depois da assinatura.

	Certificado da autenticação	Certificado da assinatura
Identifica	O sistema	Quem responde pelo conteúdo: a instituição, pelo CNPJ, ou uma pessoa, pelo CPF
Vale	Na conexão mTLS e no token	Enquanto o registro existir: fica gravada nele
Comprova	Quem está conectado	Quem respondeu pelo conteúdo e que ele não foi alterado

No ambiente oficial, a assinatura usa um certificado ICP-Brasil aceito pela política de assinatura do HubSaúde. O **Safira** assina e confere de acordo com essa política, na sua própria máquina.

E.2 Os três elementos de uma assinatura

Bundle
Reúne os registros que serão assinados, cada um com um endereço próprio no campo `fullUrl`.

Provenance
Aponta, em `target`, os registros assinados e diz, em `agent`, quem assina.

Signature
O resultado da assinatura, que o Safira grava no próprio Provenance, em `signature`.



Figura E.1. À esquerda, o Bundle com uma paciente e um resultado de exame; à direita, o Provenance, cujo `target` aponta o `fullUrl` de cada registro. Quadro do vídeo "Como a assinatura protege um registro".

O exemplo deste módulo assina uma paciente e um resultado de exame de hemoglobina:

bundle-assinatura.json

```
{
  "resourceType": "Bundle",
  "type": "collection", (1)
  "entry": [
    {
      "fullUrl": "urn:uuid:3fa85f64-5717-4562-b3fc-2c963f66afa6", (2)
      "resource": {
        "resourceType": "Patient",
        "name": [{ "family": "Souza", "given": ["Maria"] }],
        "gender": "female",
        "birthDate": "1985-04-12"
      }
    },
    {
      "fullUrl": "urn:uuid:9b2b8c1e-2f4a-4d5b-8c6d-7e8f9a0b1c2d", (3)
      "resource": {
        "resourceType": "Observation",
        "status": "final",
        "code": { "coding": [{ "system": "http://loinc.org", "code": "718-7", "display": "Hemoglobina" }] },
        "subject": { "reference": "urn:uuid:3fa85f64-5717-4562-b3fc-2c963f66afa6" },
        "valueQuantity": { "value": 13.50, "unit": "g/dL", "system": "http://unitsofmeasure.org", "code": "g/dL" } (4)
      }
    }
  ]
}
```

(1) Um Bundle do tipo `collection`: apenas um agrupamento de registros.

(2) O endereço da paciente, citado no Provenance.

(3) O endereço do resultado de exame, também citado no Provenance.

(4) O valor da hemoglobina. No passo 5, você o altera para ver a assinatura falhar.

provenance.json

```
{
  "resourceType": "Provenance",
  "target": [ (1)
    { "reference": "urn:uuid:3fa85f64-5717-4562-b3fc-2c963f66afa6" },
    { "reference": "urn:uuid:9b2b8c1e-2f4a-4d5b-8c6d-7e8f9a0b1c2d" }
  ],
  "recorded": "2026-10-15T10:00:00-03:00",
  "agent": [
    { "who": { "identifier": { "system": "urn:brasil:cpf", "value": "52998224725" } } } (2)
  ]
}
```

(1) O `target`: os dois registros que a assinatura cobre, pelos mesmos endereços do Bundle.

(2) O `agent`: quem assina, identificado pelo CPF. O número precisa ser o mesmo do certificado.

> **ATENÇÃO**
> Quem assina é identificado no Provenance pelo mesmo número que consta no certificado: o **CNPJ** da instituição, com 14 dígitos, ou o **CPF** da pessoa, com 11, sempre sem pontuação. Números diferentes resultam em recusa.

E.3 Assinar e conferir

Ao assinar, o Safira usa a chave privada sobre o conteúdo apontado em `target` e grava a Signature no Provenance. Na validação, a assinatura é conferida com a parte pública do certificado, e o conteúdo atual é comparado com o que foi assinado.

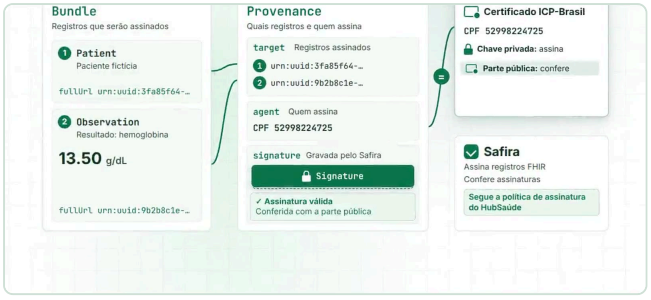


Figura E.2. Conteúdo igual ao assinado: a assinatura é válida. Quadro do vídeo "Como a assinatura protege um registro".

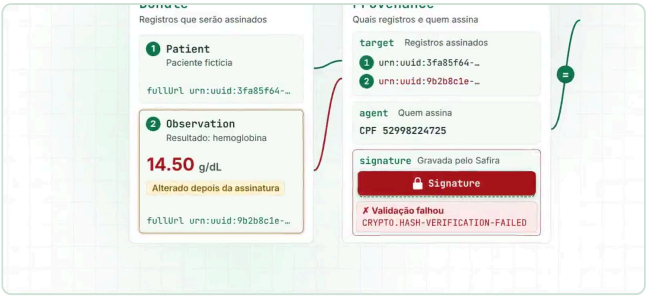


Figura E.3. Um único valor alterado depois da assinatura: a validação falha. Quadro do vídeo "Como a assinatura protege um registro".

Se um único valor mudar depois da assinatura, a validação falha. Um registro corrigido precisa ser assinado de novo.

E.4 O modo simulação

Para aprender sem um certificado ICP-Brasil, use o **modo simulação**: o mesmo processo de assinatura e validação, com certificados fictícios criados pelo próprio Safira, sem acesso à internet.

> **ATENÇÃO**
> As assinaturas simuladas **não têm validade jurídica**. Elas são marcadas como simulação e recusadas por qualquer Safira que não esteja nesse modo.

EM RESUMO

- A autenticação prova quem é o sistema na conexão; a assinatura acompanha o registro e prova quem respondeu por ele.
- O Provenance aponta o que é assinado e quem assina; a Signature é gravada nele.
- O número de quem assina precisa ser o mesmo do certificado.
- Qualquer alteração posterior à assinatura é recusada.
- O modo simulação permite praticar sem certificado ICP-Brasil.

PARTE 2

Prática guiada

A prática usa o programa do Safira diretamente, sem o HubSaúde CLI. Execute os comandos a partir da pasta `curso-hubsaude`.

1 Salvar os arquivos de exemplo

Preparar o Bundle e o Provenance que serão assinados.

Salve os dois arquivos da seção E.2 como `bundle-assinatura.json` e `provenance.json`, ou baixe-os prontos na página Materiais do curso. O Provenance identifica quem assina pelo CPF do certificado fictício que o Safira vai gerar.

☐ Passo concluído

2 Gerar os certificados fictícios

Criar a autoridade certificadora e os certificados do modo simulação.

VOCÊ DIGITA

```
$ java -jar hubsaude-safira.jar simulador pki
```

Na primeira execução, o Safira cria uma autoridade certificadora de teste, um certificado válido e um certificado revogado. A resposta, aqui formatada, mostra a situação e onde ficam os arquivos:

VOCÊ VÊ

```
AVISO: SIMULAÇÃO — sem validade jurídica ICP-Brasil
{
  "diretorio": "~/.safira-simulador/pki",
  "situacao": "GERADA",
  "raiz": "~/.safira-simulador/pki/raiz.pem",
  "ac": "~/.safira-simulador/pki/ac.pem",
  "signatario": "~/.safira-simulador/pki/signatario.p12",
  "alias": "signatario",
  "revogado": "~/.safira-simulador/pki/revogado.p12",
  "aliasRevogado": "revogado",
  "senha": "~/.safira-simulador/pki/senha.txt",
  "politicaOid": "2.16.76.1.2.3.1",
  …
  "simulacao": "SIMULAÇÃO — sem validade jurídica ICP-Brasil"
}
```

Arquivo	O que é
`signatario.p12`	O certificado válido, com a chave privada, usado para assinar.
`revogado.p12`	Um certificado revogado, usado para provocar uma recusa no passo 5.
`senha.txt`	A senha dos dois arquivos `.p12`.

☐ Passo concluído

3 Assinar

Assinar o Bundle com o certificado fictício válido.

VOCÊ DIGITA

```
$ PKI=~/.safira-simulador/pki
$ java -jar hubsaude-safira.jar assinar --modo simulacao \
      --bundle bundle-assinatura.json --provenance provenance.json \
      --p12 $PKI/signatario.p12 --senha-arquivo $PKI/senha.txt \
      --estrategia iat --saida assinada.json
```

Opção	O que faz
`--modo simulacao`	Usa os certificados fictícios no lugar do acervo ICP-Brasil.
`--bundle` e `--provenance`	Os registros a assinar e quem assina.
`--p12` e `--senha-arquivo`	O certificado de quem assina e o arquivo com a senha.
`--estrategia iat`	Registra o horário da assinatura pelo relógio do próprio sistema.
`--saida`	O arquivo que recebe o resultado.

Ao executar, o Safira exibe um aviso em destaque, `MODO SIMULAÇÃO ATIVO`, que aparece em todos os comandos desse modo. Em seguida, separe do resultado a assinatura e o Provenance assinado:

VOCÊ DIGITA

```
$ jq '.signature' assinada.json > assinatura.json
$ jq '.provenance' assinada.json > provenance-assinado.json
```

No Provenance assinado, o campo `signature` traz o momento da assinatura e quem assinou:

VOCÊ DIGITA

```
$ jq '.signature[0] | {when, who}' provenance-assinado.json
```

VOCÊ VÊ

```
{
  "when": "2026-10-30T23:33:52Z",
  "who": {
    "identifier": {
      "system": "urn:brasil:cpf",
      "value": "52998224725"
    }
  }
}
```

> **OBSERVE**
> O CPF em `who` é o mesmo do `agent` do `provenance.json`.

☐ **Passo concluído**

4 Validar

Conferir a assinatura criada.

VOCÊ DIGITA

```
$ java -jar hubsaude-safira.jar validar --modo simulacao \
      --signature assinatura.json --bundle bundle-assinatura.json \
      --provenance provenance-assinado.json | jq -r '.issue[].details.text'
```

Depois dos avisos do modo simulação, o resultado:

VOCÊ VÊ

```
Assinatura digital validada com sucesso
SIMULAÇÃO — sem validade jurídica ICP-Brasil
```

☐ **Passo concluído**

---

5 Provocar recusas

Alterar o registro depois de assinado e assinar com um certificado revogado.

Alterar o registro

Abra o `bundle-assinatura.json` no editor de texto e desça até a Observation, o resultado do exame. Troque o valor da hemoglobina e salve o arquivo:

NO EDITOR DE TEXTO: BUNDLE-ASSINATURA.JSON

linha 21	~~"valueQuantity": { "value": 13.50, …~~	→ "valueQuantity": { "value": 14.50, …

Repita o comando do passo 4. A resposta muda:

VOCÊ VÊ

```
Verificação de Hash Falhou
```

Para tratar a recusa em um script, grave o resultado em arquivo com a opção `--saida` e consulte o código de saída:

VOCÊ DIGITA

```
$ java -jar hubsaude-safira.jar validar --modo simulacao \
      --signature assinatura.json --bundle bundle-assinatura.json \
      --provenance provenance-assinado.json --saida resultado.json
$ echo $?
$ jq -r '.issue[] | .details.coding[].code, .diagnostics' resultado.json
```

VOCÊ VÊ

```
6
CRYPTO.HASH-VERIFICATION-FAILED
O SHA-256 do artefato enquadrado recomputado difere do payload assinado.
```

> **OBSERVE**
> O código de saída 6 indica assinatura recusada. O diagnóstico diz que o resumo SHA-256 do conteúdo atual difere do que foi assinado: o conteúdo não corresponde mais à assinatura.

> **ATENÇÃO**
> Ao terminar, desfaça a alteração no editor, voltando o valor para `13.50`, e salve o arquivo.

Usar um certificado revogado

Repita o passo 3 com `$PKI/revogado.p12` no lugar de `$PKI/signatario.p12`. O Safira informa `CERT.REVOKED`: um certificado revogado não pode mais assinar.

☐ **Passo concluído**

PARTE 3

Verificação

Responda sem consultar o texto. As respostas estão no final do módulo.

1. Um registro assinado teve um valor corrigido depois da assinatura. A assinatura continua válida?

2. Uma assinatura feita no modo simulação pode ser enviada ao ambiente oficial?

3. O sistema já se autentica com certificado no HubSaúde. Por que um registro ainda precisaria de assinatura?

Glossário do módulo

agent
Campo do Provenance que identifica quem assina, pelo CNPJ ou pelo CPF.

Modo simulação
Modo do Safira que usa certificados fictícios. As assinaturas não têm validade jurídica.

Provenance
Recurso FHIR que aponta os registros assinados e quem assina, e recebe a assinatura.

Safira
Ferramenta que assina registros FHIR e confere assinaturas de acordo com a política do HubSaúde.

Signature
O resultado da assinatura, gravado em `Provenance.signature`.

target
Campo do Provenance com os endereços dos registros que a assinatura cobre.

Respostas da verificação

1. *Um registro assinado teve um valor corrigido depois da assinatura. A assinatura continua válida?*

Não. Qualquer alteração depois da assinatura faz a validação falhar com `CRYPTO.HASH-VERIFICATION-FAILED`. O registro corrigido precisa ser assinado novamente.

2. *Uma assinatura feita no modo simulação pode ser enviada ao ambiente oficial?*

Não. As assinaturas simuladas não têm validade jurídica e são recusadas por qualquer Safira fora do modo simulação. No ambiente oficial, a assinatura é feita com o certificado ICP-Brasil, nos tipos aceitos pela política.

3. *O sistema já se autentica com certificado no HubSaúde. Por que um registro ainda precisaria de assinatura?*

Porque a autenticação prova quem está conectado apenas durante a conexão e o token. A assinatura fica gravada no registro e prova, a qualquer momento, quem respondeu pelo conteúdo e que ele não foi alterado.